

# 13. Security

---

CIA Triad = Confidentiality--Integrity--Availability

C;

## Confidentiality

- Ability to allow authorized persons to view data or access systems, and prevent unauthorized people from doing the same
- Encryption of both data at rest and in transit play a large role
- Access levels for accounts and the permissions they are granted
- Failures in confidentiality can result to the leaking of personal and proprietary data

# Integrity

- Ensuring that data has not been tampered with and is actually from the person (or entity) who is supposed to be sending it
- Ensuring data such as logs, ledgers, records are not modified without authorization
- Checking data received from a sender matches what they sent via hashing or checksums
- Use of certificates or other digital signatures to ensure a person or entity are who they say they are

A:

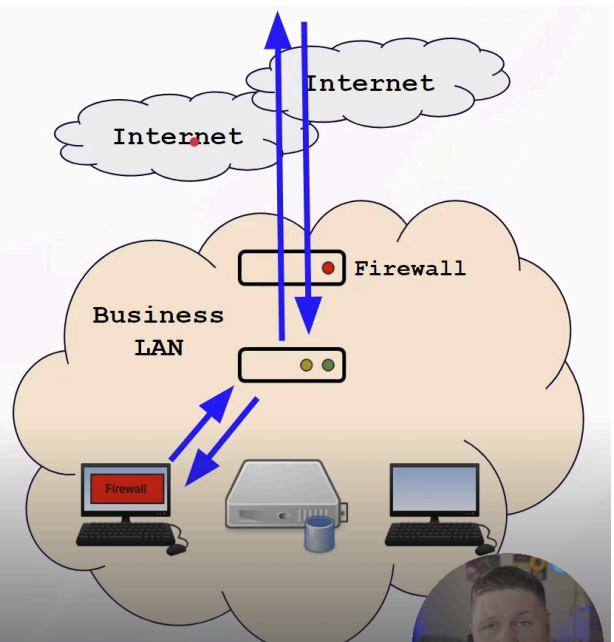
# Availability

- Systems or data are available for those who are authorized when they need them
- Keeping systems patched and updated
- Providing backups and failsafes to prevent downtime
- Preventing denial of service attacks such as DDOS

Firewall:

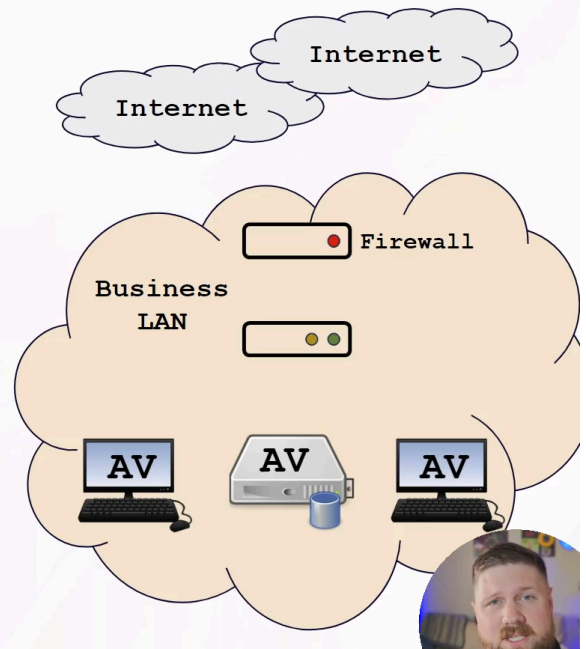
## Firewall

- Filter network traffic entering or exiting a network or computer to block unwanted or unsafe traffic
- Check Source and Destination IP Address, Port and Protocol
- Filter traffic based on rules in the access control list
- Firewalls can take the form of a physical appliance, be virtualized or function as software on a computer (host-based)
- Newer firewalls sometimes referred to as "Next-Gen" have additional capabilities such as filtering on content
- Key takeaway - hardware and/or software that can block network traffic based on IP, Port and Protocol



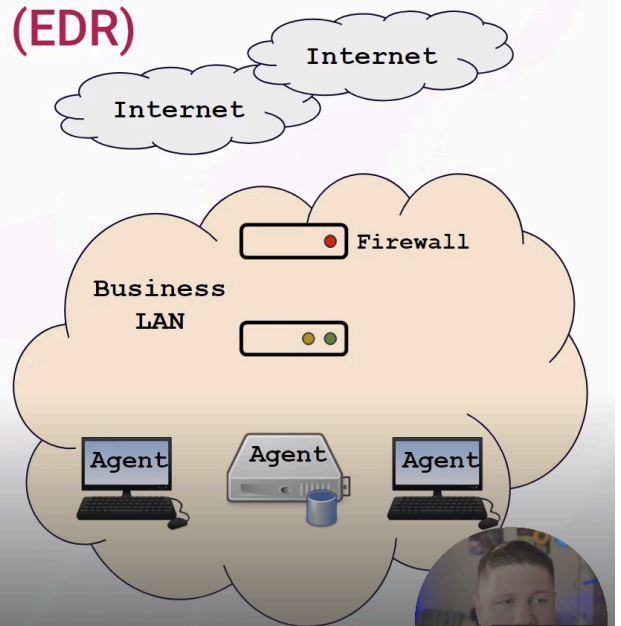
## Antivirus (AV)

- Antivirus is software installed on computers to detect, block and quarantine malicious files (malware/viruses)
- Traditionally used signature based detections to check files against lists of known malware or viruses
- As new malware or viruses emerge their signatures are added to updated lists used by AV
- Modern AV also use behavioral techniques to instead look at malicious behaviors or those that match the behavior of other malware
- Key takeaway - blocks and or quarantines malicious files (malware) by checking against signatures of other known malicious files



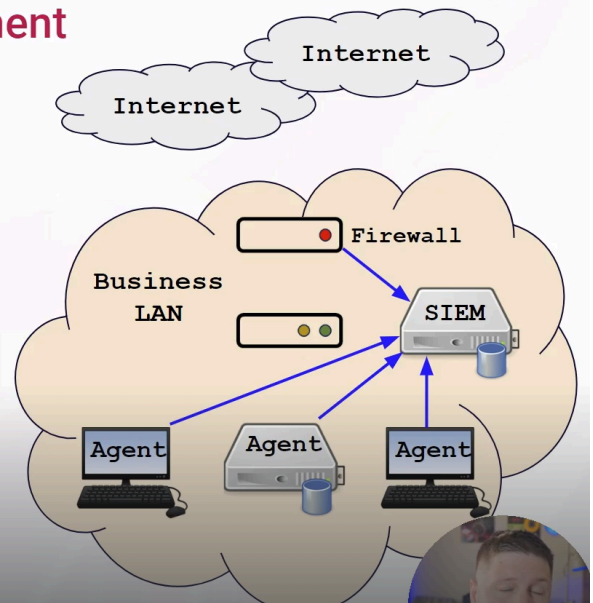
## Endpoint Detection and Response (EDR)

- Similar to an Antivirus but more advanced and capable
- Relies on multiple different sources of data (telemetry) to proactively detect and respond to threats
- Telemetry is collected by a piece of software referred to as an agent which is installed on the endpoints (computers)
- Examples of telemetry: file signatures, network connections, running processes, memory, kernel system or API calls, what files are opened or accessed
- EDRs use analysis and algorithms to automatically detect threats based on the telemetry sources by checking if it matches known harmful or dangerous behaviors
- EDRs are able to respond to threats in multiple ways such as blocking all or some network traffic or removing harmful files
- Key takeaway - advanced threat detection that collects telemetry from endpoints and uses that to determine and block threats



## Security Incident and Event Management (SIEM)

- Collect and aggregate logs from sources and tools like firewalls, EDR, log from services, threat intel
- Creates a single place to alert on, view, and action incidents or events from all of the security relevant sources and tools within a business or organization
- SIEMs can be tuned to provide different levels of alerts based on the inputs to it or correlations of multiple inputs
- Aggregating multiple source of information together provides for higher quality alerts and paints a clearer picture for security staff
- Key takeaway - piece of software to aggregate security relevant information and create alerts based on it



IAM: Identity and Access Management

## Identity and Access Management (IAM)

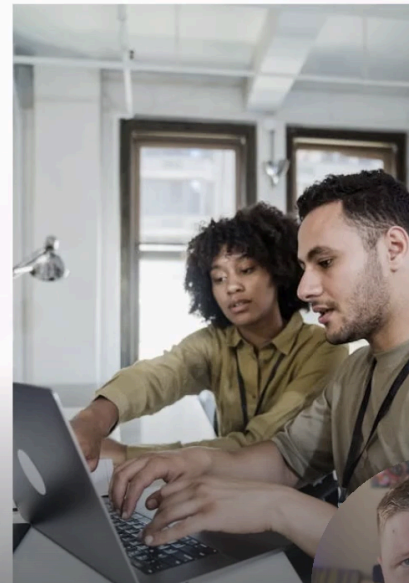
- Broad term that encapsulates how to manage who can access specific systems or data
- This includes the creation (and deletion) of various accounts like computers, domain, or specific applications and what access levels they have
- You'll sometimes hear the important aspects of IAM referred to as the 4 A's

4As:

Administration, Authentication, Authorization, and Auditing

# Administration, Authentication, Authorization, and Auditing

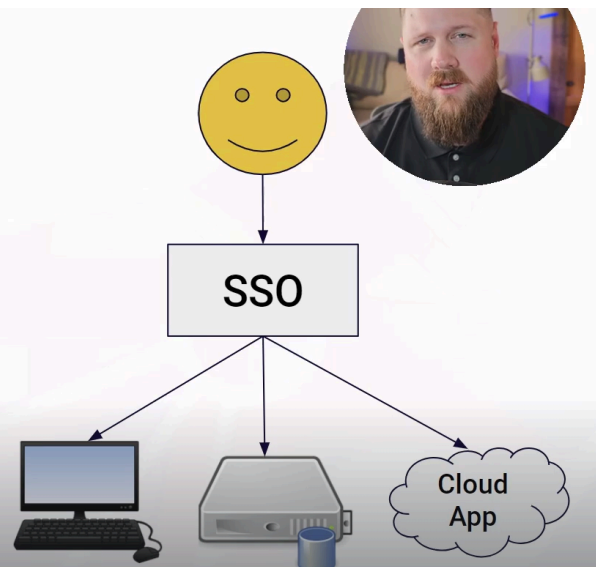
- Administration (Account Management): Refers to the creation and deletion of accounts along with managing the access levels they have
- Authentication: How verify the identity of someone logging in (username and password)
- Authorization: What resources or data a verified user is authorized to access
- Auditing: keeping records of the above for auditing, security and compliance



Sso: Single Sign On

## Single Sign-On (SSO)

- Piece of software that aggregates authentication to multiple applications or systems into one place
- Instead of having multiple usernames and passwords for all accounts, instead users log into one SSO account
- Easier for user as they don't have to remember multiple passwords, prevents bad password practices (re-use, writing down)
- Does potentially allow for single point of failure, however much easier to harden one login



# MFA Solutions

- Providing a secondary token or PIN to a predetermined phone number via SMS or call
- Installing an MFA software on a phone or tablet which can provide tokens or even push notification prompts
- Using a piece of hardware like a security USB key or smart card
- Using the built-in biometric scanning capabilities of devices like the fingerprint scanner

# Social Engineering

- Social engineering is the act of manipulating someone to give up sensitive information or perform a task
- Some example of this could be giving up a password, confidential information, clicking a link or even letting someone into a building
- Social engineering can take many forms including phishing emails, over the phone or text message or even in person
- Social engineering is one of the most successful and common avenues for cybercriminals to gain initial access into an organization

# Examples of Social Engineering

- An attacker has recovered a username and password for an employee at a company but they have MFA enabled
- The attacker contacts the user pretending to be the IT department and urges them there is an issue with their account and they need to immediately accept any MFA pushes
- The attacker logs into the account with the username and password and the employee acknowledges the MFA prompt

# Examples of Social Engineering

- An attacker sees on social media that the CEO of a company has recently been involved with a local charity event
- The attacker emails the CEO claiming to be a representative of the charity and asks if they can review a press release thanking the CEO which is attached to the email
- The attacker mentions they were supposed to send over the release a day earlier and forgot, apologizing and asking for the CEO to review ASAP
- The attachment to the email contains malware which the CEO opens on his work computer

# Examples of Social Engineering

- An attacker dresses in work clothing including a safety vest and hard hat
- They attempt to enter a secure building and when stopped by the receptionist, they let them know there is an electrical issue in the server room that needs immediate attention to prevent damage
- The attacker is let into the building and into the server room where they have unsupervised access to the servers and sensitive equipment

## What Do These All Have In Common?

- The use of a pretext, where an attacker creates a false story and/or identity to gain trust of the victim
- The attacker creates a sense of urgency that something needs to be done and possibly inserts a consequence if the request isn't fulfilled quickly
- The attacker is making a request for something



# Tips to Avoid Social Engineering

- Look for the telltales signs of social engineering including a pretext, sense of urgency, a request for something especially if it's out of character
- Verify requests via a known channel, like in person or calling their phone number
- See something - say something, don't be afraid to report anything suspicious to your security team or management

# Phishing and \*ishing

- Phishing is a type of social engineering
- Attackers attempt to solicit information or have a user perform an action via different mediums
- The most common is email phishing, however other formats like text and voice calls are used
- Common goals of phishing include:
  - gathering passwords through fake login portals
  - getting users to click links to malicious websites
  - getting users to download malicious attachments
  - gathering confidential information
  - ask you to perform as task (like buying gift cards)

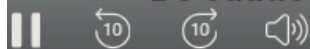
# Other Types of Phishing

- Smishing = sms phishing aka phishing via text messages
- Vishing = voice phishing, a type of phishing usually performed over phone
- Spear phishing = targeted phishing attempts which use more detailed pretexts specific to their target
- Whaling = targeting high value accounts like C-Suite (CEO, CISO, CFO etc.)
- SEO Poisoning = using sponsored or suggested posts to direct users to illegitimate support lines or websites

# Identifying and Avoiding Phishing

- Look for the usual signs of social engineering such as:
  - Use of a pretext, usually pretending to be a person or company you know or associate with
  - Introduces a sense of urgency
  - Makes a request, especially through a non-standard channel
- Check the email address or phone number it was sent from, is this how this person or company usually contacts you
- Be cautious and inspect links, hover any links before clicking to see the full url, be cautious for copycat or typosquatting domains
- If in doubt, navigate to the website yourself instead of using the link
- Be cautious of attachments

10:45



Ticket Interrupt:

**Practical Help Desk**

Heath Adams External Inbox x

**Urgent Task** <dona1djohn11447700@gmail.com> 9:59 AM (30 minutes ago)

to me

Hey Redacted,

kindly re-confirm your cell number

Thanks

CEO'S REMARK: Take This Task Serious

Get Outlook for iOS

*Handwritten red annotations:*

- Red box around "Heath Adams" with an arrow pointing to "External".
- Red box around "Urgent Task" with an arrow pointing to the email address.
- Red box around "kindly re-confirm your cell number" with an arrow pointing to "Request".
- Red box around "CEO'S REMARK: Take This Task Serious" with an arrow pointing to "!".